Rapport final de test d’intrusion

Application web YTech Solutions — état avant et après hardening

Rapport reconstruit exclusivement à partir des captures techniques finales du 02 avril 2026

Projet	YTech Solutions — sécurité applicative et validation post-hardening
Établissement	Ynov Campus Casablanca
Formation	JobInTech Cybersécurité
Encadrant	Abdelaziz HAIDAR
Année universitaire	2025-2026

Auteurs

Othmane BENAMAR — Mostafa NASIR — Ismail ELOUAKIFI — Bouchaib HERRADI — Achraf HMICHANE

Version 1.0 — 02 avril 2026

Historique du document

Version	Date	Auteur(s)	Objet
1.0	02/04/2026	Groupe YTech Solutions	Version finale reconstituée uniquement avec les captures techniques finales collectées le 02 avril 2026.

Confidentialité

Ce document est destiné au cadre pédagogique du projet YTech Solutions. Il présente une campagne de vérification de sécurité web et système menée de manière contrôlée, sans exploitation destructive ni interruption volontaire du service.

Sommaire

- 1. Résumé exécutif
- 2. Périmètre, objectifs et méthode
- 3. Outils et artefacts retenus
- 4. Synthèse des résultats
- 5. Tableau comparatif avant / après hardening
- 6. Constats techniques détaillés
- 7. Recommandations résiduelles
- 8. Conclusion

1. Résumé exécutif

Ce rapport présente l'état final de sécurité de l'application web YTech Solutions exposée via le domaine public temporaire malvina-overfamed-nonpliantly.ngrok-free.dev. Il a été reconstruit exclusivement à partir des captures finales fournies le 02 avril 2026 : reconnaissance DNS, cartographie Nmap, scans Nessus et Nikto, validation manuelle sous Burp Suite et curl, puis contrôles locaux sur le web-server (Nginx, Fail2ban, ports, PM2, logs et Lynis).

Les constats montrent une application accessible publiquement via HTTP/HTTPS au travers d'un frontal Nginx, avec un backend Node.js/Express correctement limité à l'interface locale 127.0.0.1:5001. Les contrôles applicatifs confirment le fonctionnement du mécanisme CSRF, un rejet propre des accès non autorisés via l'endpoint de vérification/authentification, et des en-têtes de sécurité cohérents sur les réponses observées.

Sur le plan de l'infrastructure, Nginx est actif et valide, Fail2ban est actif avec la jail sshd chargée, PM2 gère le processus ytech-backend sous l'utilisateur adminn, et les logs applicatifs confirment une activité réelle sur les endpoints métiers et d'authentification. Le score Lynis final atteint 84, confirmant un niveau de durcissement renforcé.

Le scan Nessus final visible dans les captures ne montre plus de vulnérabilités critiques, hautes ou moyennes. L'état résiduel constaté se limite à un élément faible et à des éléments informationnels. Le scan Nikto, quant à lui, confirme des informations SSL et met en évidence des limites liées au tunnel ngrok (multiples IP, en-têtes spécifiques ngrok, erreurs de connexion/fingerprinting), qui doivent être interprétées comme des contraintes de contexte plutôt que comme des failles directement imputables à l'application elle-même.

Au regard de ces éléments, le niveau de risque global est évalué comme élevé avant hardening, puis modéré après hardening et validation finale.

2. Périmètre, objectifs et méthode

Périmètre retenu

- Cible web publique : https://malvina-overfamed-nonpliantly.ngrok-free.dev
- Validation externe : DNS, Nmap, Nessus, Nikto, Burp Suite.
- Validation locale : Nginx, Fail2ban, ports en écoute, PM2, logs backend, Lynis.
- Le rapport ne couvre pas un test d'intrusion complet du db-server ; l'analyse se concentre sur le web-server et son exposition publique.

Objectifs

- Identifier la surface d'exposition Internet de l'application.
- Confirmer l'état final de sécurité après hardening.
- Documenter des preuves de remédiation et de fonctionnement.
- Comparer l'état initial et l'état final dans une logique avant / après.

Méthode

- Reconnaissance : résolution DNS et identification de la cible.
- Cartographie réseau : scan Nmap des ports 80/443.
- Scan automatisé : Nessus puis Nikto.
- Validation manuelle : Burp Suite et curl sur les endpoints de sécurité.
- Validation serveur : Nginx, Fail2ban, ports en écoute, PM2, logs et Lynis.
- Analyse comparative avant / après hardening.

3. Outils et artefacts retenus

Outil / source	Rôle dans l'évaluation	Résultat attendu / preuve
nslookup	Résolution DNS et identification de la cible publique	Nom de domaine résolu vers plusieurs IPs ngrok

Nmap	Cartographie des services Internet	Ports 80 et 443 ouverts, Nginx détecté
Nessus	Scan de vulnérabilités externe	Absence de criticité/haute/moyenne visible
Nikto	Contrôle web serveur et contexte SSL	Information SSL et limites de scan via ngrok
Burp Suite	Validation manuelle des flux web	CSRF 200, verify 401, en-têtes cohérents
curl	Reproduction manuelle et preuve textuelle	CSRF, login, HEAD HTTP
Nginx / systemctl	Validation du reverse proxy	Configuration et service actifs
Fail2ban	Protection SSH	Service actif, jail sshd chargée
ss -ltnp	Vérification de l’exposition locale	Backend limité à 127.0.0.1:5001
PM2 / PM2 logs	Gestion et preuve d’exécution du backend	ytech-backend online et journalisation réelle
Lynis	Mesure du hardening système	Indice final de 84

4. Synthèse des résultats

Axe évalué	Constat final	Appréciation
Reconnaissance	Le domaine est résolu correctement et pointe vers des adresses multiples liées au tunnel ngrok.	Conforme au contexte de publication
Surface réseau	Nmap confirme 80/tcp et 443/tcp ouverts sur la cible publique.	Exposition maîtrisée côté frontal
Scan de vulnérabilités	Nessus final : 1 niveau faible visible, le reste en informationnel.	Amélioration forte
Scan web serveur	Nikto remonte des informations SSL et des erreurs de contexte liées à ngrok.	À interpréter avec prudence
Contrôle applicatif	CSRF fonctionnel en 200 ; verify renvoie 401 non autorisé ; login invalide rejeté proprement.	Contrôles applicatifs cohérents
Reverse proxy	Nginx est actif et valide.	Correct
Protection SSH	Fail2ban est actif avec jail sshd.	Correct
Exposition backend	Le backend écoute sur 127.0.0.1:5001 uniquement.	Très bon point de sécurité
Exploitation applicative	PM2 gère correctement ytech-backend sous adminn, logs actifs.	Correct
Hardening système	Lynis final : 84.	Posture renforcée

Période	Niveau de risque global	Lecture
Avant hardening	Élevé	Configuration et contrôles encore en phase de stabilisation, posture de durcissement plus faible, résultats historiques moins favorables.
Après hardening	Modéré	Surface d'exposition mieux comprise, backend isolé localement, mécanismes de sécurité fonctionnels, scan externe final limité à du faible / informationnel.

5. Tableau comparatif avant / après hardening

La colonne « Avant » synthétise l'état observé au début des phases de correction du projet. La colonne « Après » s'appuie uniquement sur les preuves techniques visibles dans les captures finales retenues dans ce rapport.

Contrôle	Avant hardening	Après hardening	Statut
Résolution et cartographie de la cible	L'exposition publique n'était pas encore suffisamment documentée.	nslookup et Nmap identifient correctement le domaine, les IPs associées et les ports 80/443.	Documenté
Exposition HTTP/HTTPS	La publication publique devait encore être validée proprement.	Nmap confirme l'ouverture de 80/tcp et 443/tcp ; le frontal Nginx est visible.	Validé
Gestion des vulnérabilités	L'état initial présentait	Nessus final ne montre plus	Amélioré

	davantage de points à corriger.	de criticité/haute/moyenne visible ; 1 faible, reste informationnel.	
Mécanisme CSRF	Flux de protection encore en cours de stabilisation.	Burp et curl confirment un endpoint /api/auth/csrf-token fonctionnel en HTTP 200 avec token JSON.	Corrigé
Contrôle d'accès / auth	Les parcours d'authentification devaient être clarifiés.	Burp /verify renvoie 401 et curl /login invalide est rejeté avec message JSON explicite.	Corrigé
En-têtes HTTP	Les réponses devaient être revues dans le cadre du hardening.	Burp et curl montrent des en-têtes de sécurité cohérents (CSP, HSTS, X-Frame-Options, etc.).	Amélioré
Reverse proxy Nginx	Configuration à stabiliser et à valider formellement.	nginx -t est réussi et systemctl confirme un service actif.	Corrigé
Protection SSH	Protection anti-bruteforce non encore consolidée dans le livrable initial.	Fail2ban actif avec jail sshd chargée.	Corrigé
Exposition du backend	Le cloisonnement du backend devait être prouvé.	ss -ltnp montre Node.js sur 127.0.0.1:5001 uniquement.	Corrigé
Pilotage applicatif	La supervision de l'application n'était pas encore formalisée.	PM2 montre ytech-backend online sous adminn ; métriques et logs disponibles.	Corrigé
Hardening système	Posture de durcissement incomplète.	Lynis final à 84.	Amélioré

6. Constats techniques détaillés

Cible applicative testée

La capture ci-dessous présente la page d'accueil effectivement exposée au moment des validations finales. Elle matérialise la cible applicative utilisée pendant la campagne de test.

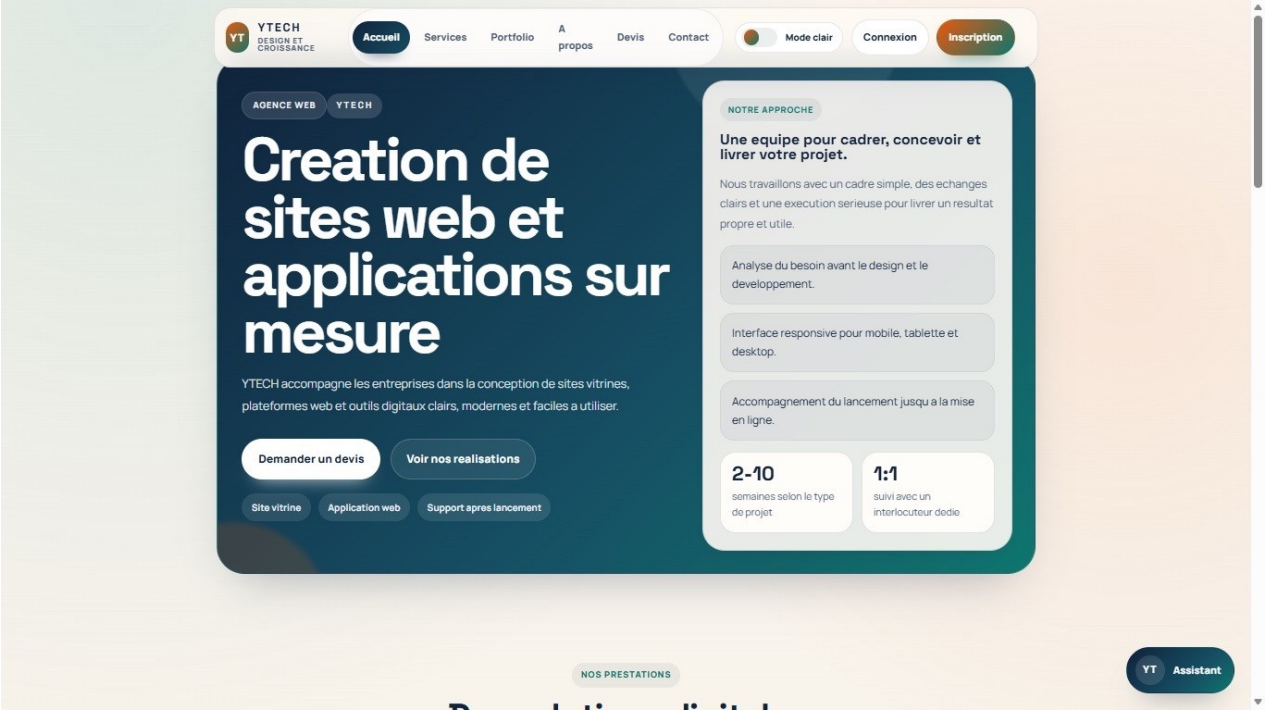

Figure A — Cible applicative publique : page d'accueil YTech Solutions.

6.1 Reconnaissance DNS

La résolution DNS de la cible publique montre un nom de domaine ngrok pointant vers plusieurs adresses IP, ce qui est cohérent avec un service de tunnelisation et de répartition d'infrastructure.

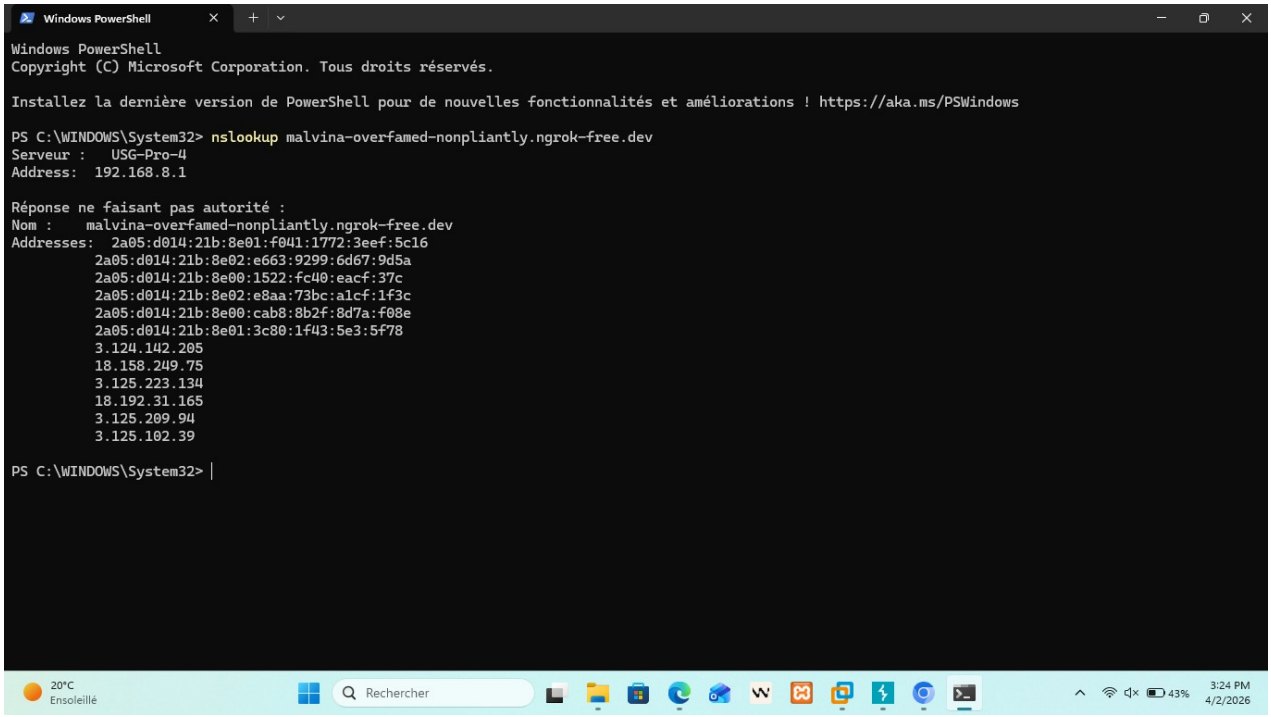

Figure 1 — Résolution DNS de la cible publique via nslookup.

6.2 Cartographie Nmap

Le scan Nmap confirme que l'hôte répond, avec 80/tcp ouvert en HTTP et 443/tcp ouvert en ssl/http. Les réponses observées mettent en évidence des redirections, l'usage du frontal Nginx et un certificat correspondant à *.ngrok-free.dev.

```
Windows PowerShell

PS C:\WINDOWS\System32> nmap -Pn -sV -sC -p 80,443 malvina-overfamed-nonpliantly.ngrok-free.dev
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-02 15:25 +0200
Nmap scan report for malvina-overfamed-nonpliantly.ngrok-free.dev (18.192.31.165)
Host is up (0.046s latency).
Other addresses for malvina-overfamed-nonpliantly.ngrok-free.dev (not scanned): 18.158.249.75 3.125.223.134 3.124.142.205 3.125.102.39 3.125.209.94 2a05:d014:21b:8e02
:e663:9299:6d67:9d5a 2a05:d014:21b:8e02:e8aa:73bc:a1cf:1f3c 2a05:d014:21b:8e01:f041:1772:3eef:5c16 2a05:d014:21b:8e00:cab8:8b2f:8d7a:f08e 2a05:d014:21b:8e01:3c80:1f43
:5e3:5f78 2a05:d014:21b:8e00:1522:fc40:eacf:37c
rDNS record for 18.192.31.165: ec2-18-192-31-165.eu-central-1.compute.amazonaws.com

PORT    STATE SERVICE  VERSION
80/tcp  open  http
| fingerprint-strings:
|   DNSStatusRequestTCP, DNSVersionBindReqTCP, GenericLines, Help, NULL, RPCCheck, RTSPRequest, SSLSessionReq, X11Probe:
|     HTTP/1.1 400 Bad Request
|     Content-Length: 11
|     Connection: close
|     Content-Type: text/plain
|   FourOhFourRequest:
|     HTTP/1.0 307 Temporary Redirect
|     Content-Type: text/html; charset=utf-8
|     Location: https:///nice%20ports%2C/Tri%6Eity.txt%2ebak
|     Date: Thu, 02 Apr 2026 13:25:11 GMT
|     Content-Length: 80
|     href="https:///nice%20ports%2C/Tri%6Eity.txt%2ebak">Temporary Redirect</a>.
|   GetRequest:
|     HTTP/1.0 307 Temporary Redirect
|     Content-Type: text/html; charset=utf-8
|     Location: https:///
|     Date: Thu, 02 Apr 2026 13:25:08 GMT
|     Content-Length: 45
|     href="https:///">Temporary Redirect</a>.
|   HTTPOptions:
|     HTTP/1.0 307 Temporary Redirect
|     Location: https:///
|     Date: Thu, 02 Apr 2026 13:25:08 GMT
|_    Content-Length: 0
|_http-title: Did not follow redirect to https://malvina-overfamed-nonpliantly.ngrok-free.dev/
443/tcp open  ssl/http Golang net/http server
| fingerprint-strings:
|   DNSVersionBindReqTCP, GenericLines, Help, RPCCheck, RTSPRequest, tor-versions:
|     HTTP/1.1 400 Bad Request
|     Content-Type: text/plain; charset=utf-8
|     Connection: close
|     Request

20°C Ensoleillé   Rechercher   42%   3:26 PM 4/2/2026
```

Figure 2 — Nmap : identification de la cible et des ports 80/443.

```
Windows PowerShell

|     Connection: close
|     Request
|   FourOhFourRequest:
|     HTTP/1.0 421 Misdirected Request
|     Connection: close
|     Content-Type: text/plain
|     Date: Thu, 02 Apr 2026 13:25:12 GMT
|     Content-Length: 142
|     Received a request for different Host than the current tunnel.
|     Current Endpoint: malvina-overfamed-nonpliantly.ngrok-free.dev
|     Requested Host:
|   GetRequest, HTTPOptions:
|     HTTP/1.0 421 Misdirected Request
|     Connection: close
|     Content-Type: text/plain
|     Date: Thu, 02 Apr 2026 13:25:11 GMT
|     Content-Length: 142
|     Received a request for different Host than the current tunnel.
|     Current Endpoint: malvina-overfamed-nonpliantly.ngrok-free.dev
|_    Requested Host:
| ssl-cert: Subject: commonName=*.ngrok-free.dev
| Subject Alternative Name: DNS:*.ngrok-free.dev, DNS:ngrok-free.dev
| Not valid before: 2026-03-29T17:12:52
|_Not valid after:  2026-06-27T17:12:51
|_ssl-date: TLS randomness does not represent time
|_http-server-header: nginx
|_http-title: Site doesn't have a title (text/plain).
2 services unrecognized despite returning data. If you know the service/version, please submit the following fingerprints at https://nmap.org/cgi-bin/submit.cgi?new-s
ervice :
==============NEXT SERVICE FINGERPRINT (SUBMIT INDIVIDUALLY)==============
SF-Port80-TCP:V=7.99%I=7%D=4/2%Time=69CE6E34%P=i686-pc-windows-windows%r(N
SF:ULL,5D,"HTTP/1\.1\x20400\x20Bad\x20Request\r\nContent-Length:\x2011\r\n
SF:Connection:\x20close\r\nContent-Type:\x20text/plain\r\n\r\n")%r(GetRequ
SF:est,C6,"HTTP/1\.0\x20307\x20Temporary\x20Redirect\r\nContent-Type:\x20t
SF:ext/html;\x20charset=utf-8\r\nLocation:\x20https:///\r\nDate:\x20Thu,\x
SF:2002\x20Apr\x202026\x2013:25:08\x20GMT\r\nContent-Length:\x2045\r\n\r\n
SF:<a\x20href=\"https:///\">Temporary\x20Redirect</a>\.\n\n")%r(HTTPOption
SF:s,70,"HTTP/1\.0\x20307\x20Temporary\x20Redirect\r\nLocation:\x20https:/
SF://\r\nDate:\x20Thu,\x2002\x20Apr\x202026\x2013:25:08\x20GMT\r\nContent-
SF:Length:\x200\r\n\r\n")%r(RTSPRequest,5D,"HTTP/1\.1\x20400\x20Bad\x20Req
SF:uest\r\nContent-Length:\x2011\r\nConnection:\x20close\r\nContent-Type:\
SF:x20text/plain\r\n\r\n")%r(X11Probe,5D,"HTTP/1\.1\x20400\x20Bad\x20Reque
SF:st\r\nContent-Length:\x2011\r\nConnection:\x20close\r\nContent-Type:\x2
SF:0text/plain\r\n\r\n")%r(FourOhFourRequest,10C,"HTTP/1\.0\x20307\x20Temp

20°C Ensoleillé   Rechercher   42%   3:26 PM 4/2/2026
```

Figure 3 — Nmap : détails sur 443/tcp, header nginx et certificat associé au tunnel.

6.3 Nessus final

Les captures Nessus finales montrent un scan complété avec une répartition dominée par les éléments informationnels et un seul élément faible visible. Aucun élément critique, haut ou moyen n'est visible dans les captures finales retenues.

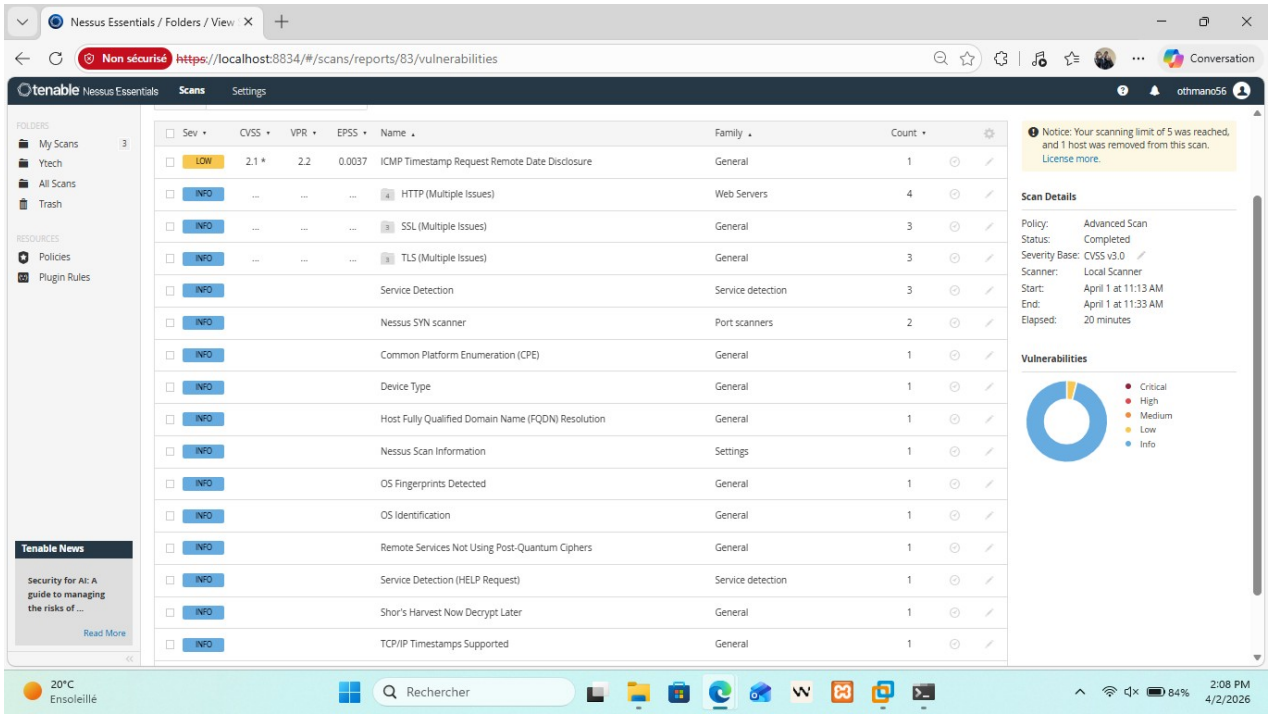

Figure 4 — Nessus final : vue de synthèse des vulnérabilités.

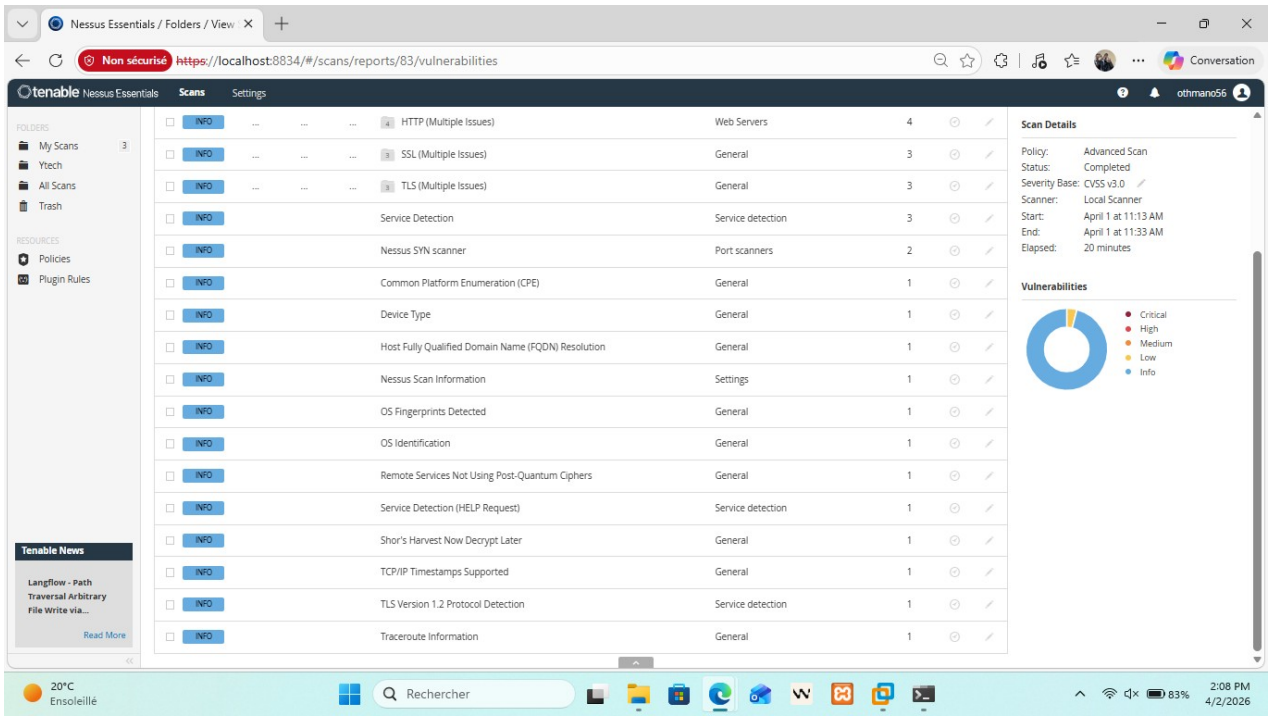

Figure 5 — Nessus final : détails du scan et répartition par sévérité.

6.4 Nikto

Nikto remonte des informations SSL et des limites de scan dues au contexte ngrok : multiples IPs, certificat générique, en-tête ngrok-error-code et erreurs de connexion/fingerprinting. Ces éléments sont utiles pour contextualiser le test, mais ne doivent pas être interprétés comme des failles applicatives autonomes.

```
┌──(deathgun㉿kali)-[~]
└─$ nikto -h https://malvina-overfamed-nonpliantly.ngrok-free.dev
- Nikto v2.6.0
---------------------------------------------------------------------------
+ Your Nikto installation is out of date.
+ Target IP:          18.158.249.75
+ Target Hostname:    malvina-overfamed-nonpliantly.ngrok-free.dev
+ Target Port:        443
---------------------------------------------------------------------------
+ SSL Info:           Subject:  /CN=*.ngrok-free.dev
                      CN:       *.ngrok-free.dev
                      SAN:      *.ngrok-free.dev, ngrok-free.dev
                      Ciphers:  TLS_AES_128_GCM_SHA256
                      Issuer:   /C=US/O=Let's Encrypt/CN=E8
+ Platform:           Unknown
+ Start Time:         2026-04-02 15:30:09 (GMT2)
---------------------------------------------------------------------------
+ Server: No banner retrieved
+ Multiple IPs found: 18.158.249.75, 3.125.223.134, 3.124.142.205, 18.192.31.165, 3.125.209.94, 3.125.102.39, 2a05:d014:21b:8e01:f041:1772:3eef:5c16, 2a05:
d014:21b:8e02:e663:9299:6d67:9d5a, 2a05:d014:21b:8e00:cab8:8b2f:8d7a:f08e, 2a05:d014:21b:8e00:1522:fc40:eacf:37c, 2a05:d014:21b:8e01:3c80:1f43:5e3:5f78, 2a
05:d014:21b:8e02:e8aa:73bc:a1cf:1f3c
+ [999100] /: Uncommon header(s) 'ngrok-error-code' found, with contents: ERR_NGROK_6024.
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ ERROR: ** Error limit (20) reached for host, giving up. Last error: opening stream: ssl connect failed. **
+ ERROR: ** Consider using mitmproxy to avoid TLS fingerprinting. **
- STATUS: Completed 203 requests (~3% complete, ~27.1 minutes left): currently in plugin 'Site Files'
- STATUS: Running average: Not enough data.
+ Scan terminated: 20 errors and 1 item reported on the remote host
+ End Time:           2026-04-02 15:30:55 (GMT2) (46 seconds)
---------------------------------------------------------------------------
+ 1 host(s) tested

┌──(deathgun㉿kali)-[~]
└─$
```

Figure 6 — Nikto : résultats de scan dans le contexte d'exposition via ngrok.

6.5 Burp Suite

Burp Suite a été utilisé pour valider manuellement les échanges applicatifs. La première capture montre l'endpoint /api/auth/csrf-token en HTTP 200 avec retour JSON. La seconde montre /api/auth/verify en HTTP 401 Unauthorized, ce qui confirme une protection cohérente sur un accès non authentifié.

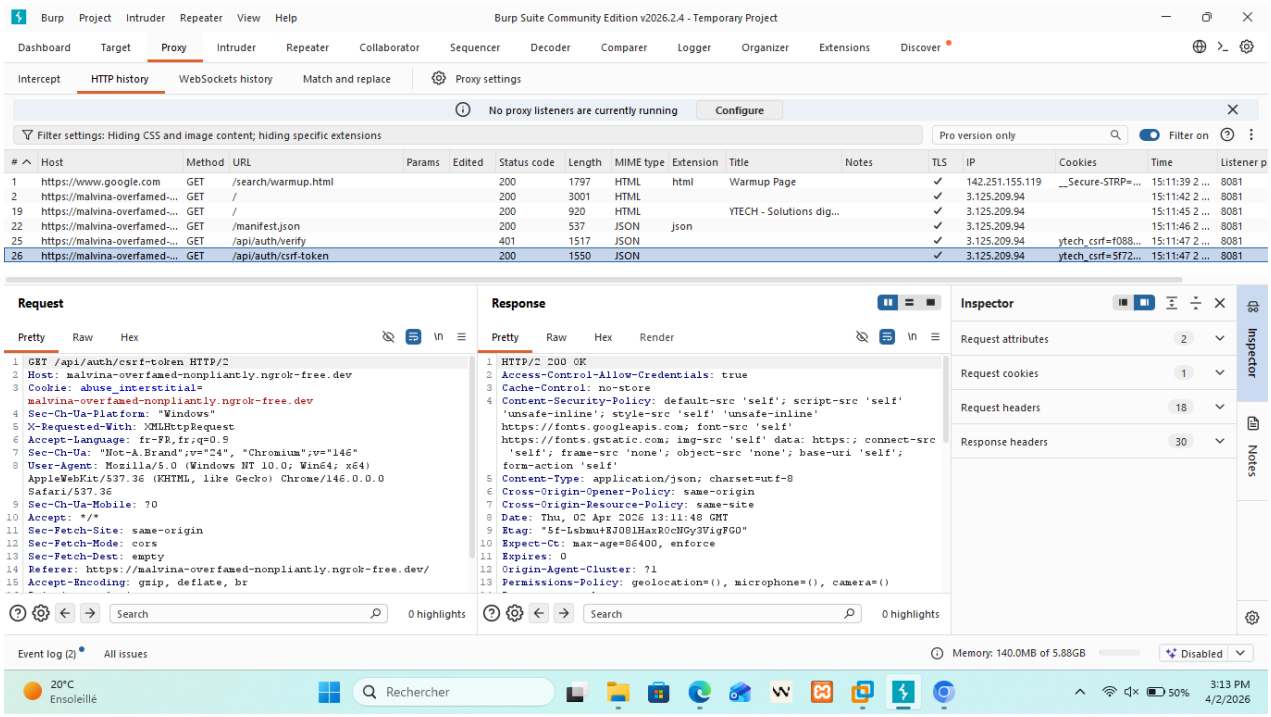

Figure 7 — Burp Suite : /api/auth/csrf-token en HTTP 200.

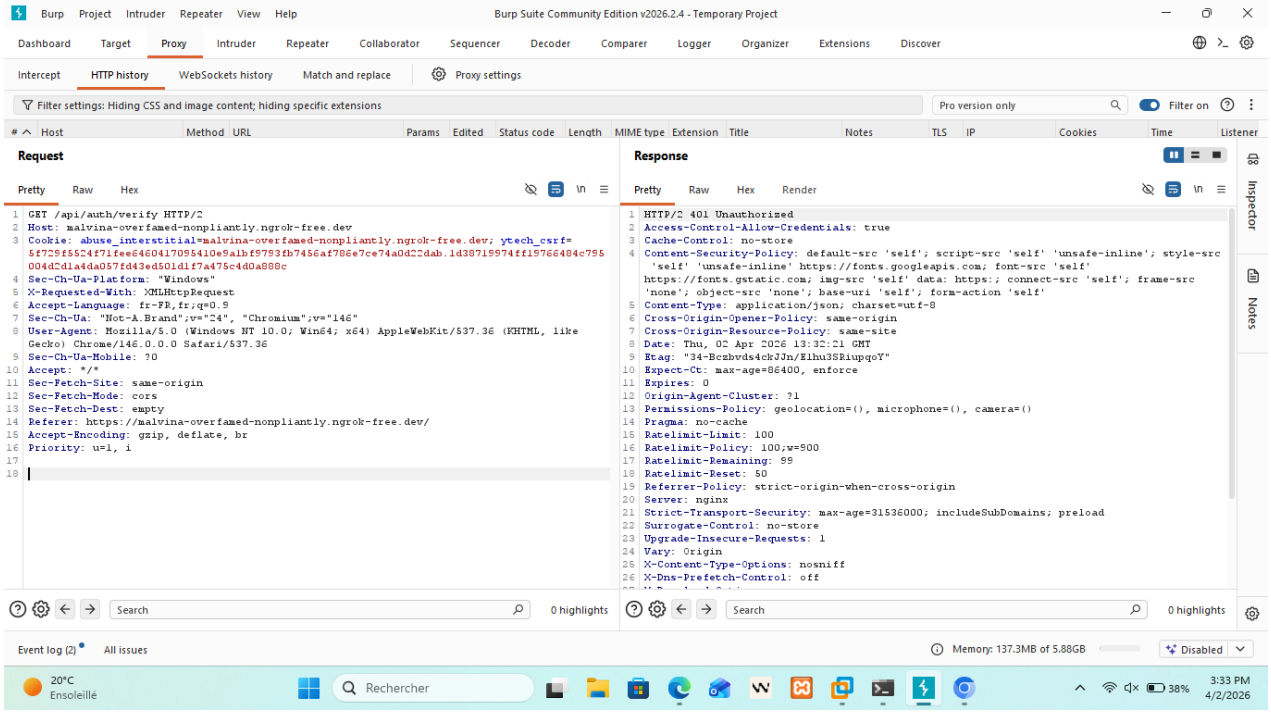

Figure 8 — Burp Suite : /api/auth/verify en HTTP 401 Unauthorized.

6.6 Validation manuelle avec curl

Les tests curl corroborent les observations faites sous Burp. L'endpoint CSRF renvoie bien un token, le login invalide est rejeté proprement et la requête HEAD confirme la réponse HTTP/2 200 du frontal Nginx.

```
root@web-server: ~
root@web-server:~# curl -i "https://malvina-overfamed-nonpliantly.ngrok-free.dev/api/auth/csrf-token" \
-H "Origin: https://malvina-overfamed-nonpliantly.ngrok-free.dev" \
-H "Referer: https://malvina-overfamed-nonpliantly.ngrok-free.dev/"
HTTP/2 200
access-control-allow-credentials: true
access-control-allow-origin: https://malvina-overfamed-nonpliantly.ngrok-free.dev
cache-control: no-store
content-security-policy: default-src 'self'; script-src 'self' 'unsafe-inline'; style-src 'self' 'unsafe-inline' https://fonts.googleapis.com; font-src 'self' https:/
/fonts.gstatic.com; img-src 'self' data: https:; connect-src 'self'; frame-src 'none'; object-src 'none'; base-uri 'self'; form-action 'self'
content-type: application/json; charset=utf-8
cross-origin-opener-policy: same-origin
cross-origin-resource-policy: same-site
date: Thu, 02 Apr 2026 13:35:09 GMT
etag: "5f-xCQr6qGBFFuSmPmN65uNnuapzr0"
expect-ct: max-age=86400, enforce
expires: 0
origin-agent-cluster: ?1
permissions-policy: geolocation=(), microphone=(), camera=()
pragma: no-cache
ratelimit-limit: 100
ratelimit-policy: 100;w=900
ratelimit-remaining: 98
ratelimit-reset: 783
referrer-policy: strict-origin-when-cross-origin
server: nginx
set-cookie: ytech_csrf=571b49b430dc4c8ff0a89a5e25f8a19fb7f7ff223b26c1a978aa5e61af9b76ce.b3b07e3251cef9c6ee9311aad1ac3b1c251aac2047150b835709c7057348c22f; Max-Age=8640
0; Path=/; Expires=Fri, 03 Apr 2026 13:35:09 GMT; SameSite=Lax
strict-transport-security: max-age=31536000; includeSubDomains; preload
surrogate-control: no-store
upgrade-insecure-requests: 1
vary: Origin
x-content-type-options: nosniff
x-dns-prefetch-control: off
x-download-options: noopen
x-frame-options: DENY
x-xss-protection: 1; mode=block
content-length: 95

{"success":true,"csrfToken":"571b49b430dc4c8ff0a89a5e25f8a19fb7f7ff223b26c1a978aa5e61af9b76ce"}root@web-server:~#
```

Figure 9 — curl : validation de /api/auth/csrf-token et retour du token JSON.

```
root@web-server: ~
root@web-server:~# curl -i -X POST "https://malvina-overfamed-nonpliantly.ngrok-free.dev/api/auth/login" \
-H "Origin: https://malvina-overfamed-nonpliantly.ngrok-free.dev" \
-H "Referer: https://malvina-overfamed-nonpliantly.ngrok-free.dev/" \
-H "Content-Type: application/json" \
--data '{"email":"admin@ytech.ma","password":"TON_VRAI_MDP"}'
HTTP/2 401
access-control-allow-credentials: true
access-control-allow-origin: https://malvina-overfamed-nonpliantly.ngrok-free.dev
cache-control: no-store
content-security-policy: default-src 'self'; script-src 'self' 'unsafe-inline'; style-src 'self' 'unsafe-inline' https://fonts.googleapis.com; font-src 'self' https:/
/fonts.gstatic.com; img-src 'self' data: https:; connect-src 'self'; frame-src 'none'; object-src 'none'; base-uri 'self'; form-action 'self'
content-type: application/json; charset=utf-8
cross-origin-opener-policy: same-origin
cross-origin-resource-policy: same-site
date: Thu, 02 Apr 2026 13:35:40 GMT
etag: "3b-CE19fMlmVHY8EZHhxgi0vm9xhp4"
expect-ct: max-age=86400, enforce
expires: 0
origin-agent-cluster: ?1
permissions-policy: geolocation=(), microphone=(), camera=()
pragma: no-cache
ratelimit-limit: 5
ratelimit-policy: 5;w=900
ratelimit-remaining: 4
ratelimit-reset: 753
referrer-policy: strict-origin-when-cross-origin
server: nginx
set-cookie: ytech_csrf=a84d49955d02daff892315621853a539c0cb2a6537f25db5c0b44bd10b58225f.f4c50fae2b16fe155ce4f5a2bd464853154b2ebf4e087fa9f5b4bc1c0c7378d6; Max-Age=8640
0; Path=/; Expires=Fri, 03 Apr 2026 13:35:37 GMT; SameSite=Lax
strict-transport-security: max-age=31536000; includeSubDomains; preload
surrogate-control: no-store
upgrade-insecure-requests: 1
vary: Origin
x-content-type-options: nosniff
x-dns-prefetch-control: off
x-download-options: noopen
x-frame-options: DENY
x-xss-protection: 1; mode=block
content-length: 59

{"success":false,"error":"Email ou mot de passe incorrect"}root@web-server:~#
```

Figure 10 — curl : rejet propre d'une tentative de connexion invalide (HTTP 401).

```
root@web-server:~# curl -I "https://malvina-overfamed-nonpliantly.ngrok-free.dev/"
HTTP/2 200
accept-ranges: bytes
content-type: text/html
date: Thu, 02 Apr 2026 13:36:08 GMT
etag: "69cd3042-2f4"
last-modified: Wed, 01 Apr 2026 14:48:34 GMT
server: nginx
content-length: 756

root@web-server:~#
```

Figure 11 — curl -I : validation de la réponse HTTP/2 200 du site.

6.7 Validation Nginx

Le test de configuration Nginx est réussi et le service est actif. Cette preuve confirme la solidité de la couche de reverse proxy en état final.

```
sudo systemctl status nginx --no-pager
nginx: the configuration file /etc/nginx/nginx.conf syntax is ok
nginx: configuration file /etc/nginx/nginx.conf test is successful
● nginx.service - A high performance web server and a reverse proxy server
     Loaded: loaded (/usr/lib/systemd/system/nginx.service; enabled; preset: enabled)
     Active: active (running) since Thu 2026-04-02 08:33:02 UTC; 5h 3min ago
       Docs: man:nginx(8)
    Process: 1332 ExecStartPre=/usr/sbin/nginx -t -q -g daemon on; master_process on; (code=exited, status=0/SUCCESS)
    Process: 1368 ExecStart=/usr/sbin/nginx -g daemon on; master_process on; (code=exited, status=0/SUCCESS)
   Main PID: 1378 (nginx)
      Tasks: 3 (limit: 2206)
     Memory: 4.1M (peak: 4.9M)
        CPU: 288ms
     CGroup: /system.slice/nginx.service
             ├─1378 "nginx: master process /usr/sbin/nginx -g daemon on; master_process on;"
             ├─1379 "nginx: worker process"
             └─1380 "nginx: worker process"

Apr 02 08:33:01 web-server systemd[1]: Starting nginx.service - A high performance web se…er...
Apr 02 08:33:02 web-server systemd[1]: Started nginx.service - A high performance web ser…rver.
Hint: Some lines were ellipsized, use -l to show in full.
root@web-server:~#
```

Figure 12 — Nginx : configuration valide et service actif.

6.8 Validation Fail2ban

Fail2ban est actif et la jail sshd est chargée. Cette configuration renforce la résistance du service SSH face aux tentatives répétées.

```
root@web-server:~# sudo systemctl status fail2ban --no-pager
sudo fail2ban-client status
● fail2ban.service - Fail2Ban Service
     Loaded: loaded (/usr/lib/systemd/system/fail2ban.service; enabled; preset: enabled)
     Active: active (running) since Thu 2026-04-02 08:32:59 UTC; 5h 3min ago
       Docs: man:fail2ban(1)
   Main PID: 988 (fail2ban-server)
      Tasks: 5 (limit: 2206)
     Memory: 35.5M (peak: 68.2M)
        CPU: 23.005s
     CGroup: /system.slice/fail2ban.service
             └─988 /usr/bin/python3 /usr/bin/fail2ban-server -xf start

Apr 02 08:32:59 web-server systemd[1]: Started fail2ban.service - Fail2Ban Service.
Apr 02 08:33:01 web-server fail2ban-server[988]: 2026-04-02 08:33:01,308 fail2ban.configreader   [988]: WARNING '… 'auto'
Apr 02 08:33:03 web-server fail2ban-server[988]: Server ready
Hint: Some lines were ellipsized, use -l to show in full.
Status
|- Number of jail:      1
`- Jail list:   sshd
root@web-server:~#
```

Figure 13 — Fail2ban : service actif et jail sshd chargée.

6.9 Ports en écoute

La commande ss -ltnp montre une séparation claire entre le frontal web et le backend applicatif. Nginx écoute sur le port 80, tandis que le backend Node.js est limité à 127.0.0.1:5001. Cela constitue une preuve forte de non-exposition directe du backend.

```
root@web-server:~# ss -ltnp | grep -E ':80|:443|:5001|:5002'
LISTEN 0      511          0.0.0.0:80        0.0.0.0:*    users:(("nginx",pid=1380,fd=5),("nginx",pid=1379,fd=5),("nginx"
,pid=1378,fd=5))
LISTEN 0      511        127.0.0.1:5001      0.0.0.0:*    users:(("node /var/www/Y",pid=1869,fd=19))

LISTEN 0      511             [::]:80           [::]:*    users:(("nginx",pid=1380,fd=6),("nginx",pid=1379,fd=6),("nginx"
,pid=1378,fd=6))
root@web-server:~#
```

Figure 14 — ss -ltnp : backend limité à 127.0.0.1:5001.

6.10 PM2 et exploitation du backend

PM2 confirme que le processus ytech-backend est bien en ligne sous l'utilisateur adminn. La seconde capture montre les métriques du processus et les commandes d'exploitation associées.

```
root@web-server: ~
root@web-server:~# sudo -u adminn -H pm2 list
sudo -u adminn -H pm2 status
sudo -u adminn -H pm2 describe ytech-backend

| id | name | namespace | version | mode | pid | uptime | ↺ | status | cpu | mem | user | watching |
|---|---|---|---|---|---|---|---|---|---|---|---|---|
| 0 | ytech-backend | default | 1.0.0 | fork | 1869 | 5h | 0 | online | 0% | 60.5mb | adminn | disabled |

| id | name | namespace | version | mode | pid | uptime | ↺ | status | cpu | mem | user | watching |
|---|---|---|---|---|---|---|---|---|---|---|---|---|
| 0 | ytech-backend | default | 1.0.0 | fork | 1869 | 5h | 0 | online | 0% | 60.5mb | adminn | disabled |

Describing process with id 0 - name ytech-backend

status              online
name                ytech-backend
namespace           default
version             1.0.0
restarts            0
uptime              5h
script path         /var/www/YTech-Web-Application/backend/server.js
script args         N/A
error log path      /home/adminn/.pm2/logs/ytech-backend-error.log
out log path        /home/adminn/.pm2/logs/ytech-backend-out.log
pid path            /home/adminn/.pm2/pids/ytech-backend-0.pid
interpreter         node
interpreter args    N/A
script id           0
exec cwd            /var/www/YTech-Web-Application/backend
exec mode           fork_mode
node.js version     20.20.2
node env            N/A
watch & reload      ✗
unstable restarts   0
created at          2026-04-01T14:50:05.424Z

Actions available

km:heapdump
km:cpu:profiling:start
km:cpu:profiling:stop
km:heap:sampling:start
km:heap:sampling:stop
```

Figure 15 — PM2 : ytech-backend online sous adminn.

```
root@web-server: ~
interpreter         node
interpreter args    N/A
script id           0
exec cwd            /var/www/YTech-Web-Application/backend
exec mode           fork_mode
node.js version     20.20.2
node env            N/A
watch & reload      ✗
unstable restarts   0
created at          2026-04-01T14:50:05.424Z

Actions available

km:heapdump
km:cpu:profiling:start
km:cpu:profiling:stop
km:heap:sampling:start
km:heap:sampling:stop

Trigger via: pm2 trigger ytech-backend <action_name>

Code metrics value

Used Heap Size          19.12 MiB
Heap Usage              73.59 %
Heap Size               25.98 MiB
Event Loop Latency p95  2.09 ms
Event Loop Latency      0.87 ms
Active handles          4
Active requests         0
HTTP                    0.01 req/min
HTTP P95 Latency        3403.7499999999995 ms
HTTP Mean Latency       16.5 ms

Divergent env variables from local env

SUDO_COMMAND  /usr/local/bin/pm2 restart ytech-backend --update-env

Add your own code metrics: http://bit.ly/code-metrics
Use `pm2 logs ytech-backend [--lines 1000]` to display logs
Use `pm2 env 0` to display environment variables
Use `pm2 monit` to monitor CPU and Memory usage ytech-backend
root@web-server:~#
```

Figure 16 — PM2 : détails du processus et métriques.

6.11 Logs PM2

Les logs PM2 montrent une activité réelle sur l'application : endpoints d'authentification, tableaux de bord, messages, quotes, contact, logout et récupération du token CSRF. Cette preuve complète la validation fonctionnelle.

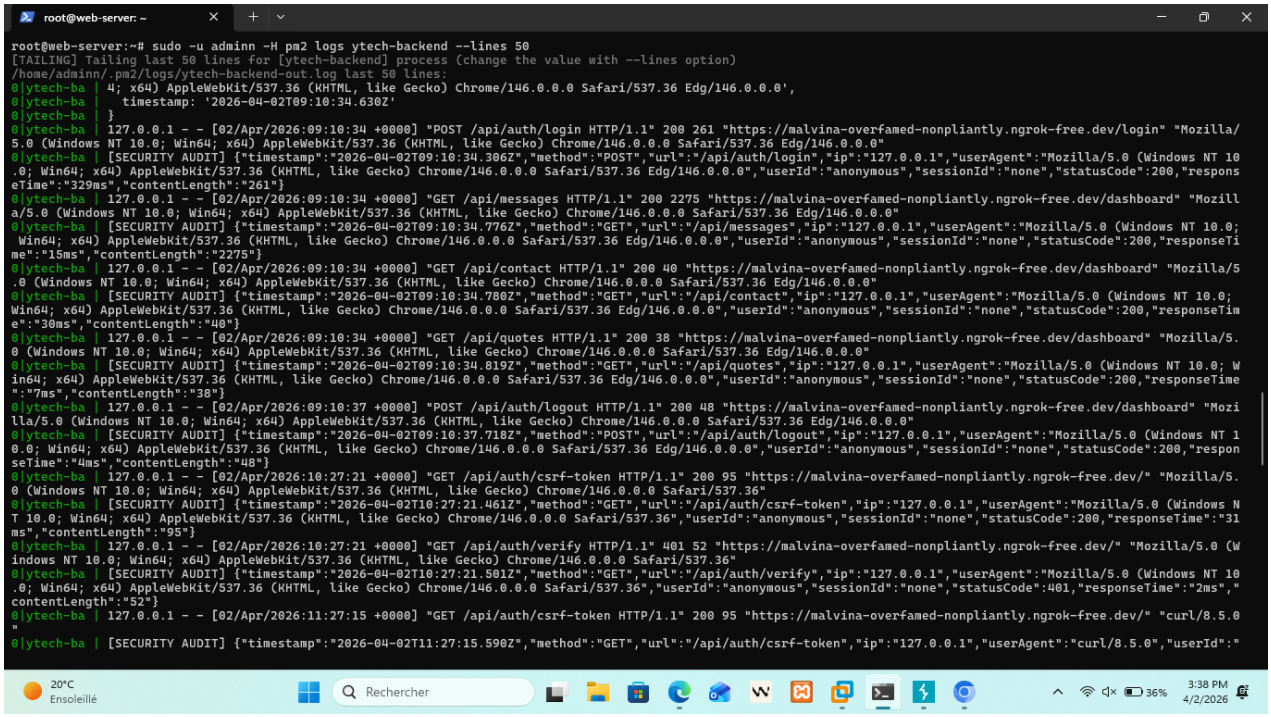

Figure 17 — PM2 logs : activité applicative et sécurité.

6.12 Lynis

Lynis affiche un hardening index final de 84. Cet indicateur confirme un niveau de durcissement système renforcé après les corrections apportées.

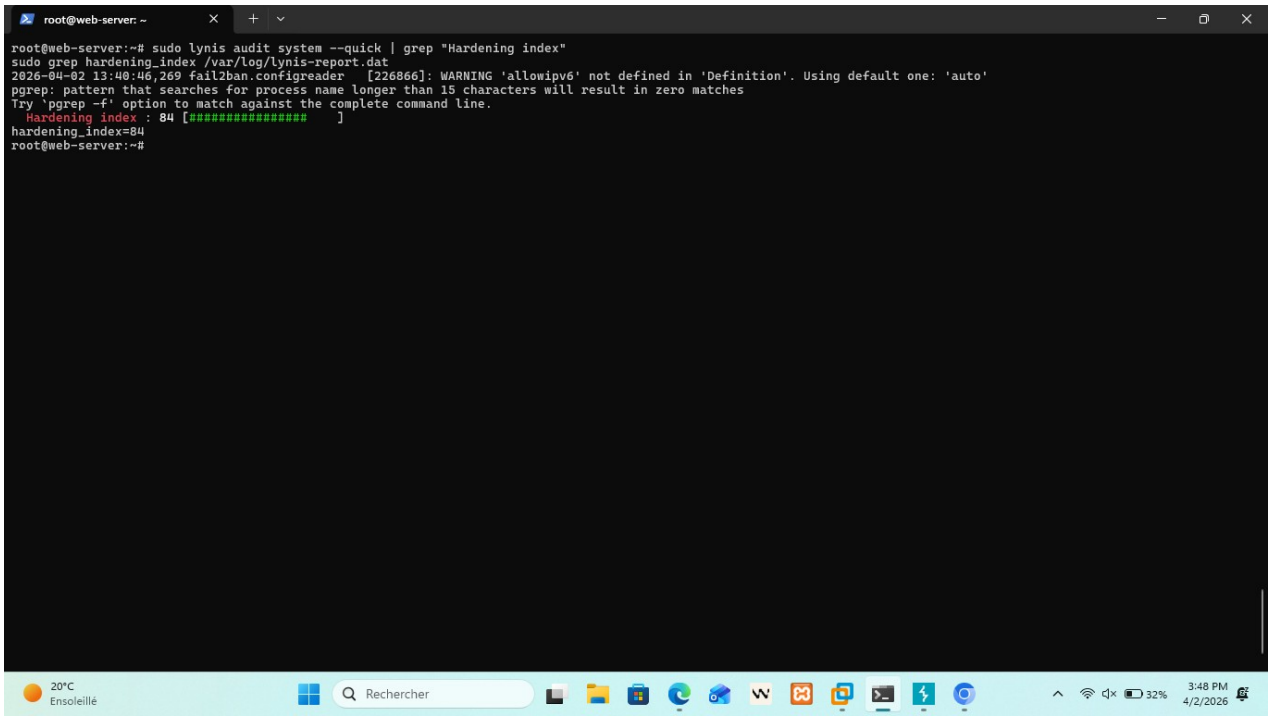

Figure 18 — Lynis : hardening index final à 84.

7. Recommandations résiduelles

- Maintenir un cycle de revalidation à chaque changement de configuration ou déploiement.
- Prévoir à terme une exposition sans tunnel temporaire ngrok pour obtenir des résultats de fingerprinting et de certificats plus représentatifs d'un environnement cible final.
- Conserver l'isolement du backend sur 127.0.0.1 et documenter cette exigence comme règle d'exploitation.

- Surveiller régulièrement les logs PM2/Nginx et l’état de Fail2ban.
- Poursuivre la revue des en-têtes HTTP, de la CSP et des mécanismes d’authentification à chaque évolution applicative.

8. Conclusion

Sur la base exclusive des captures techniques finales retenues dans ce rapport, l’application web YTech Solutions présente un état de sécurité sensiblement amélioré après hardening. Les preuves convergent : DNS et Nmap documentent l’exposition publique, Nessus montre un état résiduel limité, Nikto apporte un contexte utile malgré les contraintes ngrok, Burp et curl valident les flux de sécurité applicatifs, et les preuves locales confirment la maîtrise du reverse proxy, des services de sécurité, de l’isolement du backend et du hardening système.

Le niveau de risque global est ainsi ramené à un niveau modéré après remédiation. Dans le cadre d’un projet pédagogique, cet état final est cohérent, défendable et appuyé par une chaîne de preuves techniques complète.